PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Cybersécurité et RGPD des collectivités

03-720 Cybermalveillance et CNIL - Cybersécurité et RGPD des collectivités territoriales — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Les petites communes sont les plus vulnérables et les moins conscientes du risque.
2. La conformité au RGPD est une démarche continue et non un état figé.
3. L'AIPD évalue les risques d'un traitement pour la vie privée avant sa mise en œuvre.

Profil et risques des collectivités

Notion	À retenir
Étude de maturité	Collectivités de **moins de 25000 habitants** (**99 %** des **34945** communes, 2/3 des Français ; 1178 répondants). **1 sur 10** attaquée dans l'année, surtout par **hameçonnage** (**46 %**) ; interruption des services dans **40 %** des cas.
Moyens limités	**80 %** ont **< 10 postes** ; budget informatique **< 5000 €** pour **65 %**, budget cyber **< 2000 €** pour **75 %**. Seules **14 %** se disent préparées, **19 %** ont une procédure de réaction. Frein principal : connaissances (**45 %**).

Indicateurs clés de la partie I

71 %
Interlocuteurs principaux (prestataires informatiques)

72 %
Gestion de la sécurité externalisée

85 %
Outils répandus (sauvegardes et antivirus)

62 %
Outils répandus (pare-feu)

10 %
Utilisation de la double authentification

62 %
Utilisation d'équipements personnels

88 %
Équipement personnel : téléphone

51 %
Équipement personnel : clé USB

Méthode de sensibilisation des agents

Notion	À retenir
Les cinq clés	1. **Prise de conscience** (risques multiples) ; 2. **Implication de tous** (alerter responsable) ; 3. **Bonnes ressources** ; 4. **Répétition** (hygiène numérique) ; 5. **Vérification** (quiz, faux hameçonnage).
Le programme en trois actes	Repose sur **4 fondamentaux** (thèmes, supports, canaux, pilote). **Acte 1** : réunion lancement ; **Acte 2** : cœur (4 périodes) ; **Acte 3** : clôture (bilan, satisfaction).

Synthèse du RGPD en collectivité

Notion	À retenir
Le cadre	Applicable depuis le **25 mai 2018**. Logique de **responsabilisation** et documentation. Sanctions CNIL jusqu'à **20 millions d'euros**. 6 bases légales.
Le DPO	Désignation obligatoire (interne, externe ou mutualisé). Doit être **indépendant** et sans **conflit d'intérêts**. Notification à la CNIL par **téléservice**.
Plan d'action	1. **Recenser** (registre) ; 2. **Trier** (minimisation) ; 3. **Respecter les droits** (réponse sous **1 mois**) ; 4. **Sécuriser** (notification violation sous **72 heures**).
Risques et tiers	AIPD si **2 des 9 critères** réunis. Sous-traitant : clauses **article 28**. Vidéoprotection : conservation **1 mois** max (sauf caméras piétons : **6 mois**).

Pièges et confusions

⚠ Croire que les plus petites communes sont les moins vulnérables.
⚠ Confondre l'usage autorisé de la liste électorale avec l'usage interdit du fichier des inscriptions scolaires pour la communication politique.
⚠ Oublier que la publication d'un événement d'état civil dans le bulletin municipal exige le consentement de l'intéressé.
⚠ Considérer la conformité comme un état figé plutôt qu'une démarche continue.

Sigles et définitions

AMF	association des maires de France et des présidents d'intercommunalité
EPCI	établissement public de coopération intercommunale
Donnée personnelle	toute information se rapportant à une personne physique identifiée ou identifiable
Traitement de données personnelles	toute opération sur ces données, collecte, conservation, consultation, communication, même sur papier
Responsable de traitement	détermine les finalités et les moyens d'un traitement
DPO	délégué à la protection des données qui conseille, contrôle et sert de point de contact
AIPD	analyse d'impact relative à la protection des données
Sous-traitant	traite des données pour le compte du responsable de traitement

Auto-test

1. Quelle est la durée maximale de conservation de la vidéoprotection ?
2. Quel est le délai pour répondre aux droits des personnes ?
3. Quel est le délai de notification d'une violation de données ?
4. Quel est le montant maximum des sanctions de la CNIL ?
5. À partir de combien de critères réunis doit-on réaliser une AIPD ?

Réponses : **1.** 1 mois max (6 mois pour les caméras piétons) · **2.** sous 1 mois · **3.** sous 72 heures · **4.** 20 millions d'euros · **5.** 2 des 9 critères

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.